

BlackByte 2.0 Ransomware Intrusion

Student Eva Kan

Promotor Ruslan Davletov

Introduction

Following a short hiatus, BlackByte gang has returned and decided unexpectedly to take revenge in its new and more dangerous form - BlackByte 2.0. And if the previous version acted like a regular lock, the newer one is a lock that doesn't share a common key, but instead makes an individual one for every victim.

So how does the new BlackByte 2.0 differs from its "parent"?

1. For each attack, BlackByte 2.0 **generates a unique key**, which makes data recovery without paying ransom almost impossible.
2. It uses a **new tactic to demand a ransom**. The group created a site, where they, of course, put a company's data, but also offering victims to pay not only for a key, but for - a) downloading data back, b) postponing publishing data, c) delete data from the site for once and for all (the most expensive option).

In this way, BlackByte 2.0 became not just a regular ransomware, but a complex data leakage service that uses double pressure: files are encrypted individually, and sensitive information is ready for publication. This makes attacks more sophisticated and dangerous for business.

Attack Steps

We can break down the attack into clear steps and map them to the MITRE ATT&CK® framework.

1. **Step 1: Initial Access (MITRE: Initial Access, Exploitation for Privilege Escalation)**: The attackers scanned the internet for organizations with unpatched and vulnerable Microsoft Exchange Servers. They found a target and exploited a set of known vulnerabilities called "ProxyShell" to break in. This gave them system-level privileges on the server, effectively handing them the keys to the network.
2. **Step 2: Establishing a Foothold (MITRE: Persistence, Command and Control)**: To maintain access, the attackers uploaded a "web shell" - a malicious file that acts as a backdoor → the compromised server. This allowed them remote control. They then deployed a well-known hacking tool called Cobalt Strike Beacon, which provided them with a persistent and stealthy communication channel to their command-and-control (C2) server. They also installed the legitimate remote desktop tool AnyDesk to blend in with normal traffic.
3. **Step 3: Network Exploration (MITRE: Discovery)**: With a persistent access point inside the network, the attackers began to explore. They used common network discovery tools like NetScan and AdFind to map out the environment, identify other important servers, and understand the structure of Active Directory (which manages users and computers).
4. **Step 4: Stealing Keys (MITRE: Credential Access)**: To gain even more power, the attackers used a credential-theft tool like Mimikatz. This tool scrapes usernames and passwords from a computer's memory. They successfully stole the credentials of "domain admin" accounts, which are the highest level of access in a Windows network, similar to a master key for the entire organization.
5. **Step 5: Moving Sideways (MITRE: Lateral Movement)**: Using the stolen domain admin credentials, the attackers moved freely from the initial compromised server to other critical systems. They used built-in Windows features like Remote Desktop (RDP) and PowerShell remoting to access file servers and the domain controllers that act as the brain of the network.
6. **Step 6: Data Theft (MITRE: Collection, Exfiltration)**: Before triggering the ransomware, the attackers hunted for valuable data to steal. They used a custom tool, identified as "ExByte," which automatically searched the network for files with specific extensions (like documents and databases). This stolen data was then uploaded to the MEGA NZ file-sharing service, giving the attackers leverage for a double-extortion attack: "Pay us to decrypt your files, or we will publish your stolen data."

7. **Step 7: The Final Blow - Encryption (MITRE: Impact, Defense Evasion):** Finally, the attackers deployed the BlackByte 2.0 ransomware. It used a vulnerable driver to disable the antivirus software (defense evasion) and then systematically encrypted files across the network. It also deleted backup shadow copies to prevent recovery. Each victim received a unique encryption key, making it impossible to use a universal decryption tool.

Victims and Assets

Victims

The victims of BlackByte 2.0 are primarily **organizations**, not individual home users. The attackers specifically target businesses that have vulnerable infrastructure exposed to the internet. If we categorize, the victims were:

- *Corporations and Businesses:* The primary target. The case study by Microsoft details an attack on a single organization, which suffered significant business disruption.
- *Critical Infrastructure Sectors:* According to the sources, BlackByte 2.0 also has a history of attacking government facilities, financial institutions, and food and agriculture sectors.
- *High-Profile Organizations:* The group is known for high-impact attacks, such as the one against the San Francisco 49ers of the NFL (American Football players).

Assets Impacted & Associated Risks:

- *Business Operations:* The most immediate impact. The encryption of files brings business processes to a halt, causing massive operational disruption and financial loss.
- *Confidential Data:* The attackers exfiltrate sensitive files before encryption. The risk is a "double-extortion" attack: paying for decryption and to prevent the public release of stolen data.
- *Financial Assets:* The direct ransom demand. There is also the financial cost of downtime, incident response, and system restoration.
- *IT Infrastructure:* The attack damages the integrity of servers, workstations, and backups. The risk is the costly and time-consuming process of rebuilding the entire network environment from scratch.
- *Reputational Trust:* Customers and partners lose confidence in an organization's ability to protect their data. The risk is long-term brand damage and loss of business.

Thus, the damage was financial & data-related, operational, and reputational.

Defense Recommendations

Based on the analysis from Microsoft and other security vendors, the practical steps to defend against ransomware like BlackByte 2.0 are:

Best Practices:

1. *Prioritize Patching:* Immediately update internet-facing software, especially Microsoft Exchange servers. This single step could have prevented the entire attack described by Microsoft.
2. *Enable Tamper Protection:* Use an antivirus solution with tamper protection (like Microsoft Defender) to prevent attackers from disabling your security software.
3. *Restrict Administrative Privileges:* Strictly limit the number of users with domain admin rights. This makes it harder for attackers to steal "master keys" and spread across the network.
4. *Block Suspicious Network Traffic:* Block inbound connections from known malicious IP addresses, Tor exit nodes, and unauthorized public VPN services.

Frameworks & Policies:

1. *Implement Endpoint Detection and Response (EDR):* Deploy a modern EDR solution (like Microsoft Defender for Endpoint) to gain real-time visibility into malicious activities that traditional antivirus might miss.

2. *Adopt a Strong Vulnerability Management Program*: Use tools to continuously discover, assess, and remediate vulnerabilities across your network before attackers can exploit them.
3. *Enforce the Principle of Least Privilege (PoLP)*: Ensure users and applications have only the minimum access levels necessary to perform their functions.
4. *Prepare an Incident Response Plan*: Have a tested plan in place to quickly identify, contain, and recover from a security incident, minimizing business disruption.

Role-Based Conclusion

My Role: Pentester.

Standard: NIST CSF 2.0

1. McKinsey Framework Analysis

Following the McKinsey Problem-Solving Framework, I have deconstructed the BlackByte 2.0 ransomware attack to formulate targeted, role-based hypotheses.

Stage 1: Problem Definition:

Core Problem: Organizations continue to suffer massive operational disruption and financial loss, even though the methods used by hackers are well-known and preventable.

Root Cause (5 Whys):

1. *Why were the ransomware able to steal data from victims?*
 - Because the BlackByte 2.0 ransomware was manually executed on their systems. The attackers used stolen administrator passwords to deploy it across the network, encrypting files on servers and workstations.
2. *Why were the attackers able to deploy ransomware across the entire network?*
 - Because after getting in, they could operate for days without being detected. They used tools like Mimikatz to scrape passwords from computer memory and network discovery tools (NetScan, AdFind) to map the network and locate the most important targets, all while going unnoticed.
3. *Why were the attackers able to steal these administrator passwords?*
 - Because the company's security defenses were insufficient or could be disabled. The antivirus on one server was manually turned off by the attackers because a key protection feature ("tamper protection") was not enabled. They also used legitimate remote access software (AnyDesk) to blend in with normal traffic.
4. *Why weren't the attackers detected during their days of activity inside the network?*
 - Because the company's security defenses were insufficient or could be disabled. The antivirus on one server was manually turned off by the attackers because a key protection feature ("tamper protection") was not enabled. They also used legitimate remote access software (AnyDesk) to blend in with normal traffic.
5. *Why were the attackers able to get inside the company's network in the first place?*
 - Because the company had a critical server (Microsoft Exchange) connected directly to the internet that was missing important security updates. The attackers exploited known vulnerabilities (called "ProxyShell") in this unpatched server to break in and create a secret backdoor for remote access.

Root Problem: The company *failed* to patch a critical, internet-facing server and *lacked* layered security defenses to detect and stop attackers once they were inside the network, which allowed the attackers to quietly take full control and deploy ransomware.

Stage 2: Disaggregate:

Let us break down the problem into three MECE (Mutually Exclusive, Collectively Exhaustive) sub-problems:

1. Perimeter Defense Problem: The organization's internet-facing systems were vulnerable and poorly maintained, allowing attackers to easily find an open door and break in.
 - *Threat Linkage*: This directly enabled Step 1 (Initial Access) of the attack, where the attackers exploited the unpatched Microsoft Exchange Server (ProxyShell vulnerabilities).
2. Internal Security Control Problem: Once inside, the network lacked sufficient layers of defense to limit the attacker's movement, detect their reconnaissance, and protect critical assets like administrator credentials.
 - *Threat Linkage*: This failure allowed the attacker to progress unimpeded through Steps 2, 3, and 4 (Persistence, Discovery, Credential Access). The inability to detect tools like Cobalt Strike, NetScan, and Mimikatz, or to protect against credential theft, allowed them to steal the "keys to the kingdom."
3. Detection and Response Problem: The security tools in place were either insufficient or could be easily disabled, providing no effective alarm or blocking mechanism during the critical days of attacker activity before the ransomware was deployed.
 - *Threat Linkage*: This failure is evident in Steps 5, 6, and 7 (Lateral Movement, Exfiltration, Impact). The attackers could move laterally, steal data, and even disable antivirus (due to missing tamper protection) without being stopped, culminating in the successful deployment of the ransomware across the network.

Stage 3: Prioritize:

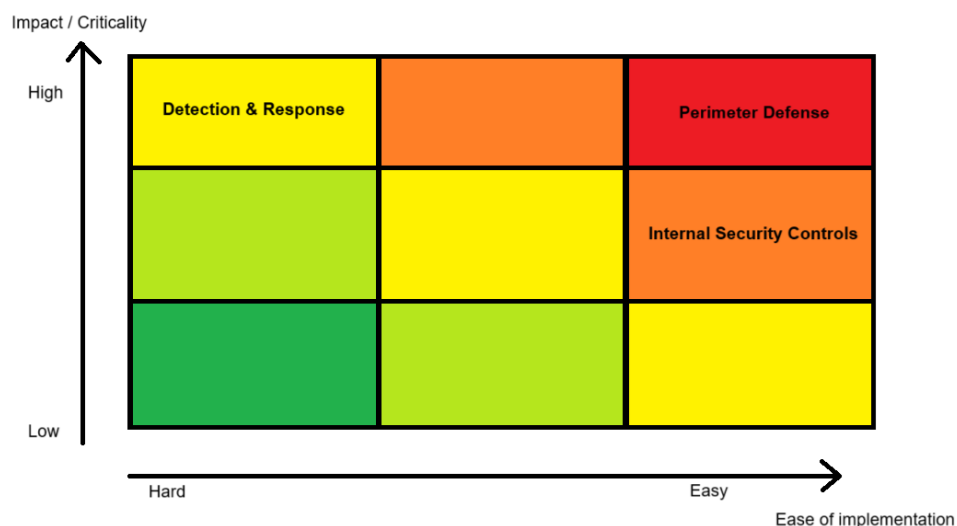


Figure 1: Risk Matrix (by Kan E.)

- Highest Priority: *The Perimeter Defense Problem*. Preventing initial access is always more effective and less costly than responding to a full-scale breach. Patching the Exchange server would have completely stopped this attack before it started, breaking the chain at Step 1. This aligns directly with the recommendation to "Prioritize Patching."
- Second Priority: *Initial Security Control Problem*. If an attacker gets inside, the next goal is to prevent them from achieving total control. By restricting administrative privileges and enforcing the Principle of Least Privilege, we directly counter Steps 3 and 4 (Credential Access). Even if the perimeter is breached, strong internal controls can contain the attacker and prevent them from stealing domain admin credentials and moving laterally. This aligns with the recommendations to "Restrict Administrative Privileges" and "Enforce the Principle of Least Privilege (PoLP)."
- Critical for Damage Limitation: *Detection and Response Problem*. We must assume some attacks will bypass preventive controls. At this stage, the goal is to detect the attacker's activity and prevent the final, most damaging steps. Implementing EDR and enabling tamper protection are crucial for detecting Cobalt Strike, Mimikatz, and blocking the ransomware deployment in Steps 5, 6, and 7. This aligns with the recommendations to "Implement EDR" and "Enable Tamper Protection."

Stage 4: Develop Hypotheses:

1. **Hypothesis 1 (Keep the Door Locked):** If we consistently update our internet-connected servers, we can stop attackers from getting inside in the first place.
2. **Hypothesis 2 (Limit Internal Access):** If we make sure users and systems only have the access they absolutely need, an attacker who gets in won't be able to steal the "master keys" to the whole network.
3. **Hypothesis 3 (Sound the Alarm):** If we use modern security tools that can't be easily turned off, we can spot an attacker's suspicious activity inside our network and stop them before they do major damage.

2. My Recommendations & Conclusion (as a Pentester)

Role-Based Conclusion: Mapping to NIST CSF 2.0

My Role: I am a **Penetration Tester (Pentester)**. My purpose is to think like an attacker, identify weaknesses, and provide evidence-based recommendations to strengthen an organization's cybersecurity posture, as defined by frameworks like the NIST Cybersecurity Framework (CSF) 2.0.

The BlackByte 2.0 attack was not an incident of a novel "zero-day" exploit, but a failure in fundamental cybersecurity practices. My standard assessment would have proactively identified these failures. The table below maps my testing activities directly to the NIST CSF 2.0, demonstrating how a pentest is a practical implementation of the framework's core functions.

NIST CSF Function	My Pentesting Activity	Direct Mapping to NIST CSF Subcategory & Outcome
Govern (GV)	Scoping the engagement to focus on critical assets like internet-facing servers and domain controllers.	GV.OC-05: Identified outcomes and services the organization depends on, ensuring the test focused on business-critical infrastructure.
Identify (ID)	Performing external footprinting and asset discovery.	ID.AM-05: Helped prioritize assets (e.g., Exchange Server) based on criticality and exposure. ID.RA-01: Actively identified and validated vulnerabilities in assets (ProxyShell).
Protect (PR)	Testing privilege escalation and lateral movement. Testing antivirus tamper protection.	PR.AA-05: Proven violation of least privilege by showing easy access to domain admin accounts. Recommended enforcing access permissions. PR.PS-01/05: Validated (and found lacking) configuration management practices that should prevent disabling security controls.
Detect (DE)	Executing Cobalt Strike, Mimikatz, and other attack tools.	DE.CM-03/09: Tested the organization's ability to monitor personnel and system activity for potentially adverse events. DE.AE-02/03: Provided a controlled scenario to analyze if the organization can correlate events from multiple sources to understand an attack.
Respond (RS)	Demonstrating the full attack chain from initial access to data exfiltration.	RS.AN-03: Provided a detailed analysis of what an attacker could do, establishing the root cause of potential incidents. RS.MI-01: Showed exactly where incidents could be contained (e.g., after initial breach but before lateral movement).
Recover (RC)	Documenting the steps required to eradicate the simulated attacker and restore systems.	RC.RP-02: Informed recovery planning by scoping and prioritizing actions based on the simulated attack's impact.

The Key Lesson in NIST Terms: The BlackByte 2.0 attack was a failure across multiple NIST CSF core functions. My role as a pentester is to operationalize the NIST CSF by providing tangible evidence of where the **Protect** controls are weak, the **Detect** capabilities are insufficient, and the **Respond** plans are untested. By doing so, I help organizations transition from a theoretical framework to a practiced, resilient defense.

My hypotheses were *confirmed*:

1. The attackers got in precisely because the company had an unpatched Microsoft Exchange Server. This was the single point of failure that started the entire attack chain. Thus, **Hypothesis 1 is proven**.
2. The attackers used a tool (Mimikatz) to steal domain admin credentials. If the organization had properly limited these powerful accounts, the attackers could not have moved across the network so easily. Thus, **Hypothesis 2 is proven**.
3. The attackers successfully disabled the antivirus on a server because "tamper protection" was not enabled. Furthermore, their use of tools like Cobalt Strike and their lateral movement went undetected for days, showing a lack of effective monitoring. Thus, **Hypothesis 3 is proven**.

References

- [1] "The five-day job: A BlackByte ransomware intrusion case study.
ThreatAssessment:BlackByteRansomware
- [2] "Here Comes BlackByte Ransomware 2.0", Heimdal Security.
<https://heimdalsecurity.com/blog/here-comes-blackbyte-ransomware-2-0/>
- [3] "BlackByte 2.0 Ransomware Techniques", MITRE ATTACK.
<https://attack.mitre.org/software/S1181/>